AI Threat Modeling Frameworks

A structured guide to identifying and mitigating risks unique to AI and machine learning systems — covering OWASP Top 10 for LLMs, OWASP ML Top 10, MITRE ATLAS, and the NIST AI Risk Management Framework.

SECTION 2.1.6

Why AI Threat Modeling Frameworks Matter

The Core Challenge

AI systems introduce a fundamentally new attack surface. Traditional threat models were not designed to account for training pipelines, embedding spaces, prompt injection, or adversarial inputs making purpose-built frameworks essential.

What These Frameworks Provide

- Structured methodologies to assess vulnerabilities across the AI lifecycle
- Common language for security teams, developers, and risk managers
- Prioritized risk catalogues mapped to real-world attack patterns
- Actionable mitigations aligned to deployment context

OWASP LLM Top 10

LLM application vulnerabilities

OWASP ML Top 10

ML system vulnerabilities

MITRE ATLAS

Adversarial tactic mapping

NIST AI RMF

Risk governance & trustworthiness

OWASP Top 10 for LLMs — Overview

The OWASP Top 10 for Large Language Models is a security framework specifically designed to identify vulnerabilities in LLM-powered applications. It gives security professionals a structured, repeatable approach to assess and mitigate LLM-related risks throughout the full system lifecycle from model selection and integration through deployment and ongoing operation.

> Unlike general application security frameworks, this list targets the unique behavioral properties of LLMs: their sensitivity to input phrasing, their reliance on training data, and their integration with external tools and APIs.

OWASP LLM Top 10 — Vulnerabilities (Part 1)

The first four vulnerabilities address how adversaries can manipulate model inputs, exploit training data, and compromise third-party integrations.

1

LLM01: Prompt Injection

Malicious inputs override system prompts when user and system-level instructions are merged, forcing the model to produce unintended outputs or leak sensitive information.

2

LLM02: Sensitive Information Disclosure

Models trained on confidential datasets or lacking proper output filtering may unintentionally reveal private or proprietary data in responses.

3

LLM03: Supply Chain Vulnerabilities

Third-party models, datasets, and plugins integrated without thorough security review or patch management introduce uncontrolled risk into the application stack.

4

LLM04: Data & Model Poisoning

Malicious actors tamper with training or fine-tuning data to alter model behavior, enabling biased outputs, hidden backdoors, or harmful content generation.

OWASP LLM Top 10 — Vulnerabilities (Part 2)

Vulnerabilities LLM05 through LLM07 address risks that emerge when model outputs are trusted uncritically, when permissions are over-provisioned, or when system-level context leaks to adversaries.

LLM05: Improper Output Handling

When generated responses are passed directly into application logic without validation or sanitization, they can trigger serious downstream vulnerabilities — including Server-Side Request Forgery (SSRF), Cross-Site Scripting (XSS), or even remote code execution. Every LLM output must be treated as untrusted input.

LLM06: Excessive Agency

LLMs granted overly broad permissions or access controls can perform unauthorized tasks, misuse elevated privileges, or cause operational failures particularly dangerous in agentic deployments where the model acts autonomously on behalf of users.

LLM07: System Prompt Leakage

Attackers can manipulate the model into revealing its system prompt due to insufficient segregation between user-facing and system-level instruction contexts. Exposed system prompts can provide roadmaps for further exploitation of the application.

OWASP LLM Top 10 — Vulnerabilities (Part 3)

The final three vulnerabilities highlight risks in the model's knowledge representation layer, its output accuracy guarantees, and its resource consumption boundaries.

LLM08: Vector & Embedding Weakness

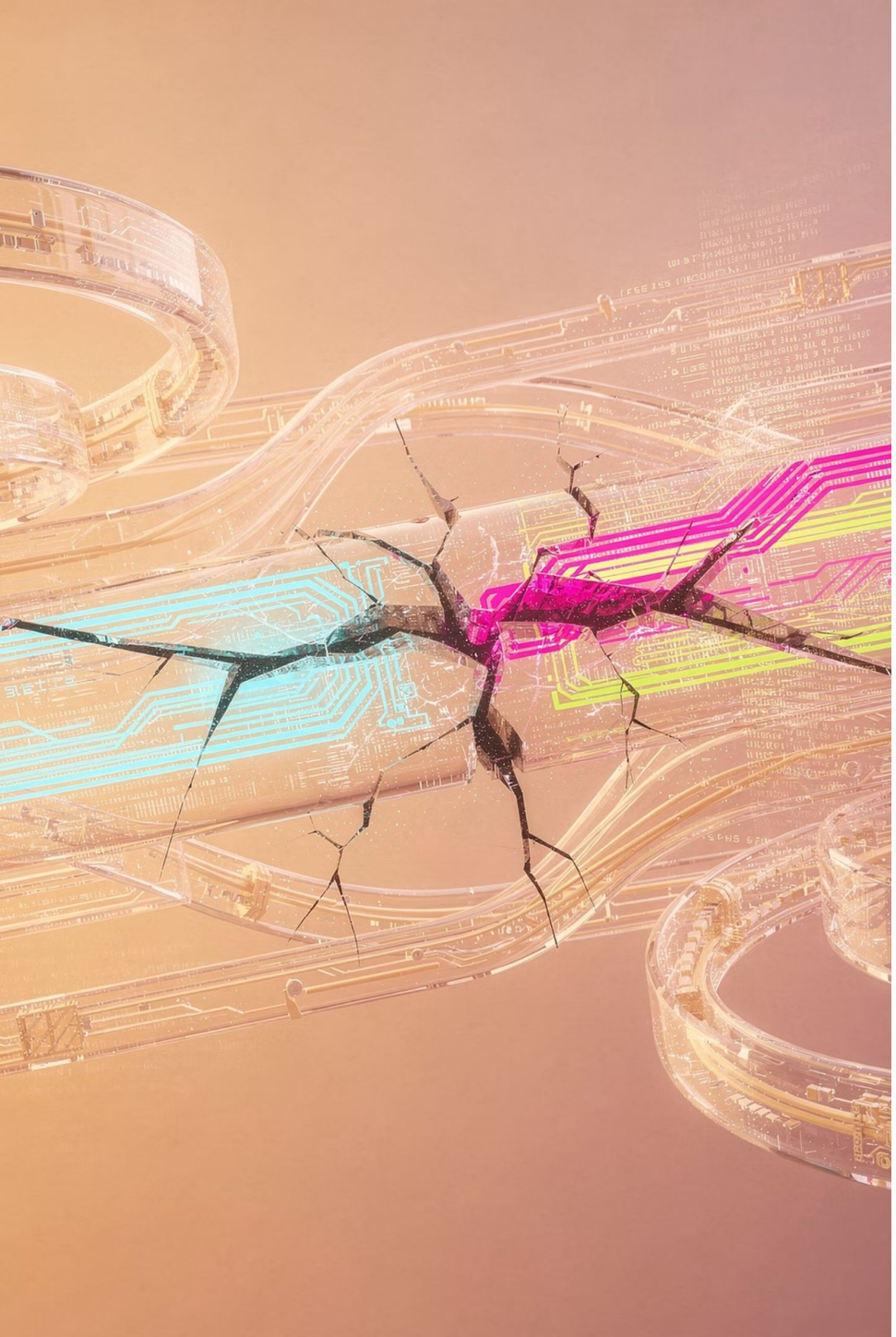
Misconfigured embedding spaces allow attackers to reconstruct sensitive content from vector representations or manipulate retrieval-augmented search results — compromising both confidentiality and integrity of the knowledge layer.

LLM09: Misinformation

Hallucinations and embedded biases impact user decision-making when outputs are not cross-validated against reliable, authoritative sources. High-stakes domains (healthcare, legal, financial) are especially exposed.

LLM10: Unbounded Consumption

Without strict rate limits or query filters, LLMs can be abused to drive uncontrolled consumption of backend compute resources, leading to service degradation or full denial of service for legitimate users.



OWASP ML Top 10 — Overview

Where the OWASP LLM Top 10 targets application-layer risks in language model deployments, the **OWASP Machine Learning Top 10** focuses on the broader ML ecosystem — the interactions between data pipelines, model architecture, and production infrastructure. It spans the full ML lifecycle: from data ingestion and training, through model deployment and inference, helping teams identify and secure systemic weaknesses that traditional AppSec frameworks miss entirely.

OWASP ML Top 10 — Vulnerabilities (Part 1)

The first four ML vulnerabilities target the data and decision boundary of machine learning systems — the most foundational and difficult to detect attack surfaces.

1

ML01: Input Manipulation Attack

Adversarially crafted inputs exploit model decision boundaries — small, deliberate perturbations trigger incorrect predictions or bypass controls entirely, particularly in image classification, fraud detection, and NLP systems.

2

ML02: Data Poisoning Attack

Malicious or misleading data injected into the training dataset corrupts model behavior, introducing biases, degrading performance, or embedding hidden backdoors that activate on specific trigger inputs.

3

ML03: Model Inversion Attack

By querying the model repeatedly and analyzing outputs, an attacker reverse-engineers the model to reconstruct sensitive training data which is a significant risk when models are trained on private records or personally identifiable information.

4

ML04: Membership Inference Attack

The attacker determines whether a specific data record was included in the training set, enabling inference of private membership which is a direct privacy violation, particularly in healthcare and financial ML applications.

OWASP ML Top 10 — Vulnerabilities (Part 2)

Vulnerabilities ML05 through ML07 address threats to model intellectual property, the integrity of the ML supply chain, and inherited risks from pre-trained models.

ML05: Model Theft

Attackers systematically query a production model to replicate its behavior, effectively stealing proprietary functionality without access to training data or weights. This causes direct financial loss and erodes competitive advantage and reputational trust.

ML06: AI Supply Chain Attack

Publicly disclosed vulnerabilities in open-source ML packages, data platforms, or model repositories are exploited to infiltrate ML pipelines mirroring traditional software supply chain threats but targeting the data and model layer specifically.

ML07: Transfer Learning Attack

Pre-trained models downloaded from public repositories may carry inherited vulnerabilities or deliberate backdoors. When used as a base for fine-tuning without thorough validation, these hidden behaviors are transferred into production systems.

OWASP ML Top 10 — Vulnerabilities (Part 3)

The final three ML vulnerabilities target output integrity and the long-term reliability of model behavior under adversarial pressure.

ML08: Model Skewing

Model behavior is systematically altered through biased or manipulated training data or feedback loops. The result is skewed outputs — discriminatory predictions or reduced accuracy that can go undetected for extended periods in production.

ML09: Output Integrity Attack

An attacker with access to improperly secured output channels manipulates or replaces the final predictions of an ML model post-inference spreading misinformation, corrupting downstream decisions, or undermining trust in the system.

ML10: Model Poisoning

Harmful code or data is deliberately introduced during training or fine-tuning, altering model parameters without visibly degrading performance metrics. Especially high impact in automated ML pipelines where human oversight is minimal.

MITRE ATLAS

ADVERSARIAL THREAT LANDSCAPE FOR ARTIFICIAL-INTELLIGENCE SYSTEMS

MITRE ATLAS is a globally accessible, community-maintained knowledge base of adversarial tactics, techniques, and procedures (TTPs) targeting AI and ML systems. Modeled after the MITRE ATT&CK framework, ATLAS maps real-world attack scenarios across each phase of the ML lifecycle — from data collection and model training through deployment and inference.

Lifecycle Phase Mapping

Attacks are categorized and mapped to specific phases of the ML pipeline enabling teams to trace adversarial goals (availability, integrity, confidentiality) back to exploitable pipeline stages.

Key Threat Focus Areas

Primary coverage includes data poisoning, model evasion, model extraction, and functional misuse of AI systems each with documented real-world case studies and suggested mitigations.

Common Adversarial Language

ATLAS provides security teams with a shared vocabulary for discussing, analyzing, and communicating AI-specific threats enabling more consistent detection engineering, red-teaming, and incident response across organizations.

NIST AI Risk Management Framework

Purpose & Scope

The NIST AI RMF is a structured, flexible guideline designed to help organizations understand, evaluate, and manage risks associated with AI systems. It is sector-agnostic and applicable to developers, operators, procurers, and decision-makers across all stages of AI deployment.
Core trustworthiness dimensions: **Safety · Security · Fairness · Privacy · Explainability · Resilience**

AI Risk Management Challenges

Measurement — Quantifying AI risk is inherently difficult due to emergent model behaviors

Tolerance — Acceptable risk thresholds vary widely by sector and use case

Prioritization — Competing risk types must be ranked against mission objectives

Management — Continuous governance is required as models and contexts evolve

1

MAP

Identify and contextualize AI risks within organizational mission and use case

2

MEASURE

Analyze and assess identified risks using quantitative and qualitative methods

3

MANAGE

Prioritize and apply mitigations; monitor ongoing risk posture

4

GOVERN

Establish policies, accountability structures, and culture for responsible AI

Key Takeaways

AI threat modeling frameworks are not optional as they are foundational to building defensible AI systems. Each framework targets a distinct layer of the stack.

OWASP LLM Top 10

Addresses 10 critical application-layer vulnerabilities in LLM deployments — from prompt injection and data poisoning to excessive agency and unbounded resource consumption. Essential for any team operating LLM-powered applications.

OWASP ML Top 10

Targets ML-specific threats across the full pipeline: input manipulation, model inversion, membership inference, transfer learning attacks, and model poisoning. Covers risks that emerge well before inference time.

MITRE ATLAS

Provides a structured, community-maintained knowledge base mapping adversarial tactics and techniques to phases of the ML pipeline — giving red teams and detection engineers a shared vocabulary and actionable guidance.

NIST AI RMF

Promotes trustworthy and responsible AI through four core governance functions — Map, Measure, Manage, and Govern — adaptable across sectors and AI system types.